Overnight Session Report

OrchestraOS

2026-09-30

CONTENTS

Overnight Session Report — 2026-09-29 to 2026-09-30

1. Security: Pulse/Toddito hardening

2. 2D Agents View — shipped

3. OD6 — compliant voice agent (research only, nothing built)

4. Fleet operations

Decisions waiting on you

CONFIDENTIAL

Overnight Session Report — 2026-09-29 to 2026-09-30

1. Security: Pulse/Toddito hardening

Confirmed the real deploy target was `brollistika/toddito` (not the fork initially assumed), then closed the full security backlog against it, re-verifying every claim from source rather than trusting the (stale, wrong-repo) `SECURITY.md` that had been used to describe it.

Fixed:

- **SEC-01** — prompt injection into scoring. Closed the fail-open on both webhooks (ElevenLabs, Vapi accepted unsigned requests if a secret wasn't set) and added runtime output validation so a manipulated model response gets rejected instead of reaching a client report.
- **SEC-02** — unauthenticated report overwrite. Added an admin-token check to the score endpoint without breaking the unauthenticated respondent flow it shares infrastructure with.
- **SEC-04** — webhook replay. Added freshness/timestamp validation and delivery idempotency; a captured webhook delivery could previously be replayed forever.
- **SEC-06** — no rate limiting. Added limits to the three most exposed endpoints; deliberately did not rate-limit the webhook itself post-SEC-04, since that risked dropping a real completed interview transcript for no security benefit.
- **Dependencies** — 17 advisories (3 critical, 6 high) resolved to 0 via a Next.js and sharp upgrade.

Mitigated, not closed (product decision required):

- **SEC-03 / SEC-08** — a respondent's session-id link is a bearer credential by the documented v1 design; anyone holding it can see that session's PII and, without a fix, could claim it on a webhook. Real, live protections now in place (a terminal session 410s before any PII returns, an already-scored report can't be overwritten, replay is blocked) bound the damage, but closing this fully means adding authentication to respondent links — a product call, not a code fix.

CONFIDENTIAL

An earlier proposed fix (enabling ElevenLabs' conversation-initiation webhook) was found and retracted before shipping: that mechanism doesn't fire for browser/SDK calls, only telephony, so it would not have worked.

2. 2D Agents View — shipped

Built and shipped a new default topology view for the fleet dashboard (`PR #137`, head `d313ec5`), replacing thin, hard-to-read stats with a live message-flow graph. Steps 1–10 of the spec landed: correct live/down agent counts, a single source of truth for message counts (three previously-disagreeing stores unified), click-to-open agent and conversation panels, and travelling message dots.

Three real bugs were caught during review and fixed before merge:

- A down agent was invisible in the topology graph regardless of filter.
- The live dashboard was, at one point, serving a build that matched no commit at all (an untracked-build-artifact gap, now closed with a build-time stamp).
- Two dashboard send paths (Cards view, chat input) silently dropped messages into a deprecated, unread directory while reporting success — a real, pre-existing bug unrelated to this feature, found during its QA pass and fixed.

Status: `PR #137` is complete, fully verified, and waiting on your DCO sign-off and merge — nothing further to do on the fleet's side.

Already scoped as a follow-up (v2, separate branch, not blocking the merge): extended time windows (out to 90 days / all), a replay control, and layer toggles, based on your comparison against the field view.

3. OD6 — compliant voice agent (research only, nothing built)

Evaluated the two repos you named (`voicebox`, `voicestudio`) as candidates for a self-hosted, compliant voice agent: neither is a drop-in — they're TTS/STT toolkits without conversation orchestration, and `voicestudio` carries a real licensing risk (AGPL-3.0 only, no commercial license available) that would matter for a closed-source

CONFIDENTIAL

product. The real path is assembly: self-hosted transcription, a local TTS engine, and an orchestration layer, with Pipecat currently looking like the better fit over LiveKit for this product's single-party, browser-mic shape.

A consent-and-retention-policy draft is ready for your review but not adopted or published — that's your call, not the fleet's to make unilaterally.

In progress: re-scoping this against `brollistika/substrate` and the `kokoro-*` repos you flagged, to check how much of this can build on existing work rather than starting from the open-source options — a SWOT is being prepared.

4. Fleet operations

Several real, self-caught issues were found and fixed in how the fleet verifies its own work and coordinates:

- A verification gap meant some "tests pass" / "type-check clean" reports across the fleet weren't actually checking anything (an empty program compiling to "success," or a shell pipe that couldn't report failure). All six known instances were found and fixed the same night, and a standing practice was adopted: every reported "green" result must be shown to actually go red when the underlying thing is broken.
- A messaging seat lost its grounding at spawn and treated legitimate coordination as suspicious — correctly cautious reasoning, applied to a false alarm. Fixed directly; it's now doing the most thorough QA work of the night.
- A scope-creep pattern was caught and corrected: once a PR is finished and waiting on you to merge, only genuine user-facing bugs should still land on it — everything else (tooling, process polish) waits.

None of the above required any decision from you; they're recorded for visibility.

Decisions waiting on you

1. Whether to enable/deploy the ElevenLabs config change closing SEC-03/08 fully (requires adding authentication to respondent links — a product call).
2. Sign-off on the OD6 consent/retention policy draft.

CONFIDENTIAL

3. Which ElevenLabs plan tier Toddito is actually on (decides whether their own zero-retention offering could close part of OD6 more cheaply).
4. `PR #137` — DCO and merge, whenever you're ready.

Nothing above is urgent; none of it blocks other work continuing.

CONFIDENTIAL